

PICEE-PA

Profilo di esecuzione governata per sistemi di IA agentica nella Pubblica Amministrazione

Policy -> Identity -> Capability -> Execution -> Evidence

Autore	Valerio Lombardi
ORCID	0009-0006-3949-6228
Versione	v1.0 - 1 settembre 2026
Stato	Proposta tecnica - preprint indipendente

Documento di ricerca indipendente. Le opinioni espresse sono esclusivamente dell'autore e non rappresentano alcuna organizzazione, ente o datore di lavoro. Il documento non costituisce consulenza legale o valutazione di conformità.

Abstract

L'intelligenza artificiale nella Pubblica Amministrazione sta passando da sistemi prevalentemente conversazionali e assistivi a sistemi capaci di selezionare strumenti, invocare servizi, orchestrare workflow e produrre effetti operativi. Questo passaggio sposta il problema di governance dal solo contenuto generato alla legittimità e controllabilità dell'azione. PICEE-PA è una proposta vendor-neutral di application profile per l'esecuzione governata di azioni proposte o avviate da sistemi di IA: Policy, Identity, Capability, Execution, Evidence. Il contributo non consiste nell'inventare singolarmente policy-as-code, identità degli agenti, least privilege, human oversight o audit - componenti già presenti in standard, linee guida e toolkit contemporanei - ma nel comporli, per azione, con requisiti propri del contesto amministrativo: finalità e procedimento, catena di delega, perimetro di autorità, supervisione significativa, reversibilità, tracciabilità e prova ricostruibile. La proposta introduce due artefatti: Administrative Execution Envelope (AEE), contratto pre-esecuzione, e Administrative Evidence Bundle (AEB), pacchetto post-esecuzione. Il paper definisce livelli di azione L0-L3, semantica fail-closed, threat model, mapping allo stato dell'arte e un piano di validazione empirica. PICEE-PA è presentato come design proposal da testare e falsificare, non come standard già validato.

Tesi in una frase

Un sistema di IA può ragionare in modo ampio, ma nella PA dovrebbe poter agire solo attraverso capacità esplicite, attribuite a identità e deleghe verificabili, autorizzate da policy applicabili, eseguite con controlli proporzionati e accompagnate da evidenze ricostruibili.

1. Perché questo paper esiste

Nel 2026 il dibattito sull'IA pubblica ha accelerato: l'AI Act è generalmente applicabile dal 2 agosto 2026, pur con il rinvio delle principali regole per i sistemi high-risk al 2 dicembre 2027 o al 2 agosto 2028 a seconda della categoria [1-3]; l'Italia ha una legge nazionale sull'IA [4]; AgID ha portato in consultazione linee guida per sviluppo e procurement [5-7]; e la Community italiana per il governo aperto ha pubblicato raccomandazioni su trasparenza, accountability, partecipazione, tracciabilità e supervisione umana [8].

Parallelamente, la tecnologia si è spostata verso agenti in grado di chiamare tool e modificare lo stato di sistemi. Le guide canadesi introducono bounded autonomy e recoverability [13]; il Regno Unito aggiorna le proprie AI Insights sugli agenti [14]; Urban Institute pubblica un playbook specifico per enti pubblici [15]; NIST tratta identità e autorità degli agenti [19]; Microsoft AGT fornisce policy, identity, sandboxing, approval e audit runtime-enforceable [22-25]. Quindi il problema non è l'assenza di controlli tecnici: è come collegarli all'autorità amministrativa e al procedimento.

2. Che cosa PICEE-PA non pretende di essere

PICEE-PA non è un nuovo modello di IA, non è un motore di policy, non è un prodotto di cybersecurity, non è un sostituto dell'AI Act o delle linee guida AgID e non è una certificazione. Non pretende di essere il primo framework ad accostare identity, policy, execution control e audit. Il Microsoft Agent Governance Toolkit, ad esempio, copre già in modo sostanziale questi livelli sul piano tecnico [22-25].

PICEE-PA propone invece un profilo applicativo per la PA: un linguaggio e una sequenza di controllo che rendano esplicita, per ogni azione significativa, la continuità tra finalità/procedimento, soggetto che richiede, identità dell'agente, delega, capability, decisione di policy, eventuale approvazione umana, esecuzione ed evidenza.

3. Il contributo proposto

Il cuore di PICEE-PA è una catena P-I-C-E-E applicata all'unità minima rilevante: l'azione. AEE descrive ex ante ciò che l'agente chiede di poter fare; AEB documenta ex post ciò che è stato autorizzato, eseguito, approvato, fallito o compensato. La distinzione tra authorization amministrativa e authorization tecnica è fondamentale: un token tecnicamente valido non dimostra che l'azione sia coerente con mandato, finalità, procedimento o responsabilità istituzionale. Questa separazione è diventata esplicita anche nella letteratura di agosto 2026 sul "democratic authorization gap" [16].

4. Scenario 2026: dal chatbot all'attore software

Un chatbot genera testo; un agente può selezionare un tool, interrogare un registro, aprire una pratica, inviare una comunicazione, generare una disposizione, modificare un record o delegare un sotto-task. Non tutti questi effetti sono equivalenti. L'adozione responsabile richiede quindi di separare almeno quattro livelli di azione:

Livello	Descrizione	Esempi	Regola di controllo
L0 - Assistivo	Nessuna modifica di stato; output informativo o bozza.	Riassunto, ricerca, bozza, spiegazione.	Logging proporzionato; verifica umana nel normale workflow.
L1 - Prepar preparatorio	Classifica, instrada, raccomanda o precompila; non produce di per sé un effetto esterno.	Triage, routing, suggerimento, precompilazione.	Policy e tracciabilità; possibilità di correzione; monitoraggio qualità.
L2 - Operativo reversibile	Modifica uno stato interno o avvia un'azione compensabile.	Aggiornamento record, apertura task, prenotazione reversibile.	Capability stretta, limiti, approval in base al rischio, rollback/compensazione.
L3 - Conseguenziale	Può incidere su diritti, risorse, obblighi, pagamenti o produrre effetti difficilmente reversibili.	Provvedimento, pagamento, blocco, notifica con effetto giuridico.	Autorizzazione umana significativa di default, salvo base normativa esplicita; evidenza forte e contestabilità.

La classificazione L0-L3 non coincide automaticamente con le categorie "high-risk" dell'AI Act. È un controllo architetturale-operativo interno: un sistema può essere non high-risk ai sensi del regolamento e richiedere comunque controlli forti su una specifica azione; viceversa la conformità normativa di un sistema high-risk non definisce, da sola, la semantica di ogni tool call.

5. Il gap: autorizzare l'azione, non solo autenticare il software

Le moderne piattaforme IAM possono dire "questo workload possiede un token valido" e i motori ABAC/Rego/Cedar possono dire "questa richiesta soddisfa una regola". Ma nella PA restano domande ulteriori: per quale finalità e quale procedimento si sta agendo? Chi ha attivato l'azione e per conto di chi? La delega è ancora valida? La capability è coerente con il ruolo e con il caso concreto? L'effetto è reversibile? È necessaria un'approvazione umana? Quale evidenza deve entrare nel fascicolo o nel registro di audit?

PICEE-PA distingue l'autorizzazione amministrativa (mandato, finalità, competenza, procedimento, responsabilità) dall'autorizzazione tecnica (identità, token, policy, capability, risorsa). Un'azione affidabile richiede che entrambe siano soddisfatte e collegate.

Questa distinzione converge con il recente concetto di democratic authorization gap: se un sistema agentico seleziona ed esegue azioni pubbliche, la catena che collega l'autorità democraticamente o legalmente fondata all'azione concreta può spezzarsi per traduzioni di mandato, deleghe ricorsive, diffusione dell'azione e ritardi nella contestabilità [16]. PICEE-PA tenta di rappresentare tale catena in forma operativa e verificabile.

6. Stato dell'arte e posizionamento di PICEE-PA

Approccio	Cosa offre	Che cosa resta da specificare per PICEE-PA
AI Act + legge italiana	Obblighi e principi su rischio, trasparenza, governance, supervisione, accountability.	Traduzione runtime per azione e collegamento a procedimento/finalità.
AgID 2026	Architetture, livelli di autonomia, ciclo di vita, sviluppo e procurement per la PA.	Contratto azione-per-azione fra mandato amministrativo e enforcement tecnico.
NIST AI RMF / ISO 42001	Governance e risk management organizzativo.	Semantica di autorizzazione/esecuzione per una singola azione agentica.
Canada 2026	Bounded autonomy, recoverability, unique agent identity, checkpoint umani, kill switch.	Profilo interoperabile che rappresenti anche procedimento/finalità ed evidenza amministrativa.
NIST agent identity	Identificazione, authorization, auditing e non-repudiation degli agenti.	Collegamento esplicito fra agent authority e autorità amministrativa/delega.
Microsoft AGT / ACS	Policy fail-closed, identity/trust, tool control, approval, sandboxing, audit/evidence.	Non è un profilo specifico della PA; PICEE-PA può mappare AEE/AEB su AGT/ACS invece di sostituirlo.
OPA / Cedar / OAuth RAR	Policy-as-code e richieste di autorizzazione ricche.	Vocabolario amministrativo, action classes, evidence bundle e lifecycle.
W3C PROV	Modello interoperabile per provenance.	Profilo di provenance orientato alla decisione/esecuzione amministrativa.
Interoperable Europe / PAIR	Strategia di adozione, interoperabilità, toolbox e riuso.	Un artefatto tecnico riusabile per autorizzazione e prova delle azioni agentiche.

La conclusione è intenzionalmente prudente: i mattoni esistono; il contributo potenziale di PICEE-PA è la loro composizione come application profile pubblico, vendor-neutral e orientato all'azione amministrativa. La novità deve essere dimostrata attraverso implementazione, mapping e validazione comparativa, non affermata per dichiarazione.

7. Il modello PICEE-PA

Policy

Rappresenta il “perché” e il perimetro: finalità, procedimento/processo, base normativa o regola organizzativa applicabile, vincoli, soglie, separazione dei compiti, retention, requisiti di supervisione e regole di escalation.

Identity

Rappresenta il “chi”: requester umano o sistema, identità dell'agente/workload, sponsor/owner, catena di delega, ruoli, autenticazione, durata delle credenziali e responsabilità nominale.

Capability

Rappresenta il “che cosa può fare”: operazione, risorsa, scope, dati accessibili, parametri consentiti, limiti quantitativi/temporali, condizioni, divieti e principio del least authority.

Execution

Rappresenta il “come e quando”: decisione fail-closed, validazione pre-tool, isolamento, rate limit, approval, meaningful human oversight, monitoraggio, kill switch, rollback/compensazione e gestione dell'incidente.

Evidence

Rappresenta il “che cosa possiamo provare”: decisione di policy, identità, delega, capability, approvazioni, versione di policy/modello/tool, effetti reali, esito, errori, provenance, hash/riferimenti e legame con registri o fascicolo quando appropriato.

Principi trasversali

Fail closed; least privilege/least authority; purpose limitation; separation of duties; policy versioning/pinning; human oversight significativo; reversibilità e compensazione; observability; incident response; interoperabilità; data governance; evidenza resistente a manomissioni; change management di modelli, tool e policy.

8. AEE - Administrative Execution Envelope

AEE è il contratto strutturato che deve esistere prima di una action call significativa. Non è necessariamente un unico file fisico: può essere una vista canonica costruita da identità, workflow, policy store e request context. Il requisito è che sia deterministico, validabile e referenziabile tramite identificatore/hash.

Campo	Scopo minimo
aee_id / correlation_id	Identificare univocamente la richiesta e collegarla all'evidenza.
purpose / process	Finalità e procedimento/processo/servizio a cui l'azione appartiene.
policy_basis	Policy applicabili: norme, regolamenti, atti interni o regole tecniche versionate.
requester	Identità del soggetto o sistema che origina la richiesta.
agent_identity	Identità crittograficamente/operativamente verificabile dell'agente o workload.
sponsor / accountable_owner	Responsabile istituzionale o owner del servizio, distinto dal modello.
delegation_chain	Catena di delega e relativi limiti/scadenze.
capability	Operazione, risorsa, scope, parametri ammessi, limiti, dati e sink.
action_class	L0-L3 con motivazione e criteri di reversibilità/impatti.
human_approval	Necessità, ruolo approvatore, separation of duties, scadenza.
versions	Versione/hash di policy, modello, tool/schema e configurazione critica.
expiry / budget	Finestra temporale, rate/budget e vincoli quantitativi.

```
{
  "aee_id": "aee-2026-09-00142",
  "purpose": "istruttoria-documentale",
```

```

"process": "case:DEMO-1042",
"requester": {"type":"human", "id":"user:123"},
"agent": {"id":"agent:triage-01", "sponsor":"role:service-owner"},
"delegation": {"scope":"case:DEMO-1042", "expires":"2026-09-01T15:00:00Z"},
"capability": {"action":"case.add_internal_note", "resource":"case:DEMO-1042"},
"action_class": "L2",
"approval": {"required": true, "role":"case-supervisor"},
"policy": {"id":"pa-case-policy", "version":"1.4.2", "sha256":"..."}
}

```

9. Semantica decisionale

1. L'agente produce un'intenzione di azione, non un diritto ad agire.
2. Il sistema costruisce/valida AEE e risolve requester, agent identity, delega e policy applicabili.
3. La capability richiesta viene verificata contro scope, risorsa, dati, budget, action class e vincoli contestuali.
4. Il motore di policy restituisce ALLOW, DENY oppure REVIEW/APPROVAL; errori, dati mancanti o policy non verificabili generano DENY/fail-closed.
5. Se richiesta, l'approvazione deve essere significativa: l'approvatore vede finalità, effetto, rischio, risorsa, proposta dell'agente e opzioni alternative; non un semplice pulsante "OK".
6. L'esecuzione avviene attraverso un enforcement point che impedisce bypass e applica isolation/rate limit/egress constraints dove necessari.
7. Il sistema osserva l'effetto reale e produce AEB, includendo eventuale rollback, compensazione o errore.
8. Incidenti, anomalie, drift o cambi significativi di policy/modello/tool possono invalidare deleghe o richiedere nuova valutazione.

10. AEB - Administrative Evidence Bundle

AEB è il record minimo che permette a un revisore tecnico o amministrativo di ricostruire l'azione senza affidarsi al racconto del modello. Non deve necessariamente contenere prompt o dati personali completi: deve poter contenere hash, riferimenti e metadata minimizzati, in linea con privacy, sicurezza e retention.

Elemento	Evidenza
identity/delegation	Requester, agent ID, owner, delega e stato al momento dell'azione.
policy decision	Policy ID/version/hash, decisione, reason code, eventuali eccezioni.
approval	Chi ha approvato, quando, con quale ruolo e quale vista informativa.
execution	Tool/API realmente invocati, risorse toccate, timestamp, transaction/execution ID.
result	Esito, effect/side-effect rilevato, output hash/riferimento e metriche pertinenti.
provenance	Origine dei dati rilevanti e trasformazioni; mapping possibile su W3C PROV.
recovery	Rollback, compensazione, kill switch, errore o incidente.
versions	Policy, modello, tool, schema, configurazione e prompt template quando necessario.
administrative linkage	Riferimento al processo/fascicolo/registro quando richiesto dal caso d'uso e dalle regole applicabili.

11. Threat model e failure modes

Rischio	Esempio	Controllo PICEE-PA
Prompt injection / untrusted content	Documento induce l'agente a invocare tool non previsti.	Capability whitelist, source labels, policy pre-tool, isolamento e fail-closed.
Confused deputy	Agente usa i privilegi del backend per una richiesta non autorizzata.	Delegation chain + requester binding + per-action scope.
Privilege escalation	Tool o credenziale eccessivamente ampia.	Least authority, credenziali brevi, action class, elevation esplicita.
Shared credentials	Più agenti usano la stessa chiave.	Workload identity univoca e audit correlabile.
Tool/schema poisoning	Descrizione tool manipolata o cambiata.	Schema/version pinning, allowlist, firma/hash e change control.
Policy drift / TOCTOU	Policy valutata cambia prima dell'esecuzione.	Policy hash/pinning e rivalutazione all'enforcement point.
Recursive delegation	Sub-agent acquisisce autorità non intesa.	Delegation budget, max depth, capability attenuation.
Irreversible side effects	Azione produce effetto non annullabile.	L3 + approval significativo + dry-run/simulation + compensation plan.
Audit tampering	Agente altera o omette le proprie tracce.	Evidence sink separato, append-only/immutability, hash/correlation.
Data exfiltration	Dati sensibili inviati a sink non autorizzato.	Data labels, sink clearance, egress policy, minimization.
Shadow agents	Automazioni non registrate agiscono su sistemi.	Agent registry, workload identity, deny unknown identities.
Automation bias	Umano approva senza comprendere.	Meaningful oversight: tempo, contesto, alternative, potere di fermare.
Model/tool version drift	Comportamento cambia dopo aggiornamento.	Version evidence, canary, revalidation e rollback.

12. Human oversight: da “human-in-the-loop” a controllo significativo

La presenza formale di un umano non garantisce controllo. La ricerca recente evidenzia che l'oversight efficace richiede conoscenza sufficiente, osservabilità, potere reale di intervento e tempo utile [17]. PICEE-PA tratta quindi la supervisione come capability e responsabilità del sistema socio-tecnico, non come checkbox.

- L'approvatore deve sapere quale effetto sarà prodotto, su quale risorsa e perché.
- Deve poter rifiutare, modificare, sospendere o chiedere informazioni aggiuntive.
- L'intervento deve avvenire prima del punto in cui l'effetto diventa irreversibile.
- Il sistema deve prevenire rubber-stamping: UI, carico, metriche e incentivi sono parte del controllo.
- Per L3 l'approvazione deve essere attribuibile a un ruolo responsabile e separata dall'agente proponente.

13. Interoperabilità e implementazione

PICEE-PA è intenzionalmente technology-neutral. Può essere implementato usando un motore esistente (Rego/OPA, Cedar o equivalente), standard IAM/OAuth, workload identity, API gateway/service mesh, sandbox e sistemi di audit/provenance. L'obiettivo è definire i dati e la semantica che devono attraversare questi componenti, non imporre uno stack.

Il Microsoft Agent Governance Toolkit è un candidato naturale per un mapping di riferimento: ACS offre policy deterministica e fail-closed con intervention points e evidence metadata [23]; AgentMesh tratta identity/delegation [25]; l'Execution Control definisce privilege elevation, isolation, rate limit, kill switch e audit integrity [24]. PICEE-PA può fornire il profilo amministrativo che popola questi controlli con purpose, process, delegation e action class.

Sul fronte europeo, PAIR e l'AI Toolbox enfatizzano interoperabilità e riuso [9-11]. Il caso SyRCI-IA di Madrid dimostra un pattern coerente: servizio AI separato dall'applicazione transazionale, interfacce strutturate, supervisione umana, valutazione formale di sicurezza/compliance e monitoraggio operativo [12]. PICEE-PA dovrebbe poter descrivere questi pattern senza legarsi a un fornitore.

14. Procurement e ciclo di vita

Per evitare che la governance sia aggiunta dopo l'acquisto, il capitolato o la progettazione dovrebbe richiedere almeno:

- API o hook per enforcement pre/post azione e possibilità di blocco indipendente dal modello;
- identità distinta di agenti/workload e credenziali short-lived con scope minimo;
- esportabilità di policy, log ed evidenze in formati documentati;
- versioning e pinning di modelli, prompt template, tool schema e policy;
- kill switch, rollback/compensazione e procedure di incident response;
- metriche per accuracy, sicurezza, override umano, false allow/deny e drift;
- assenza di lock-in sui dati di audit e possibilità di migrare il policy engine;
- documentazione di delegation, sub-agent, tool discovery e accesso a dati/sink.
- sandbox o isolamento proporzionato alle capability; egress control per dati sensibili;
- piano di dismissione: revoca credenziali, conservazione evidenze, rimozione accessi e cancellazione sicura.

15. Tre scenari esemplificativi

Scenario A - Routing documentale (L1)

L'agente classifica una richiesta e suggerisce l'ufficio competente. AEE contiene finalità di instradamento, sorgente, classificazione dati e capability "route.suggest"; l'azione non modifica il record finale senza conferma del workflow. AEB registra modello/versione, categorie candidate, decisione e correzione umana. È vicino al pattern SyRCI-IA [12].

Scenario B - Aggiornamento interno reversibile (L2)

L'agente propone di aggiungere una nota o creare un task. La capability è limitata a uno specifico caso, ha scadenza breve e budget. Una policy può richiedere approval sopra una soglia o per dati sensibili. AEB registra tool call, transaction ID e rollback se necessario.

Scenario C - Azione con effetto sui diritti/risorse (L3)

L'agente può preparare una proposta ma non produrre autonomamente l'effetto finale. AEE richiede base/purpose, reviewer qualificato e separation of duties; l'esecuzione finale è autorizzata da una persona con potere reale di decisione e produce AEB rafforzato. L'obiettivo non è automatizzare il fondamento giuridico, ma rendere verificabile la catena che conduce all'azione.

16. Piano di validazione scientifica e tecnica

Per poter sostenere un contributo scientifico, PICEE-PA deve essere valutato contro baseline e scenari riproducibili. Si propongono le seguenti ipotesi falsificabili:

Ipotesi	Test	Metriche
H1 - Riduce azioni non autorizzate	Confronto agent tool-use con/senza AEE + policy enforcement.	Unauthorized action rate; false allow/deny; bypass rate.
H2 - Migliora ricostruibilità	Incident reconstruction con log tradizionali vs AEB.	Tempo di ricostruzione; completezza; inter-rater agreement.
H3 - Mantiene interoperabilità	Implementare lo stesso profilo su due policy engines/runtime.	Portabilità schema; differenze semantiche; effort.
H4 - Riduce rubber-stamping	Confrontare approval minimale vs meaningful approval UI.	Override quality; tempo; error detection; workload.
H5 - Contiene delegation risk	Stress test multi-agent con delega ricorsiva.	Max privilege amplification; depth violations; containment.

Una reference implementation v1.0 dovrebbe quindi includere: JSON Schema AEE/AEB, policy examples, due enforcement adapter, test di prompt injection/confused deputy/recursive delegation, log append-only, action-class policy, e almeno un caso di studio con dati sintetici. Solo dopo questa fase è opportuno parlare di “framework validato”.

17. Limiti e claim ammessi

- PICEE-PA è una proposta architetturale e un profilo applicativo; non è uno standard riconosciuto né una certificazione.
- Non sostituisce analisi legale, DPIA/FRIA, valutazioni di sicurezza o procurement.
- La corretta classificazione L0-L3 dipende dal dominio e deve essere documentata.
- AEE/AEB possono introdurre overhead; minimizzazione e livelli di evidenza devono essere calibrati.
- L’audit non deve trasformarsi in raccolta indiscriminata di prompt o dati personali.
- Un human checkpoint può fallire se l’umano non dispone di competenza, tempo o reale capacità di intervento.
- La novità di PICEE-PA risiede nella composizione amministrativa e nella semantica per azione; deve essere confrontata empiricamente con AGT/ACS, Canada, NIST e altri framework.

Formula da usare pubblicamente

“PICEE-PA proposes a vendor-neutral public-administration application profile that connects administrative authorization to technical authorization for each AI-initiated action, using Policy, Identity, Capability, Execution and Evidence, with AEE/AEB as proposed interoperable artefacts.”

18. Roadmap verso una specifica riutilizzabile

Versione	Obiettivo
v1.0	Paper, vocabolario PICEE, action classes, AEE/AEB schema draft, reference demo, threat model.
v1.1	Mapping formale ad ACS/AGT, OPA/Rego e Cedar; test suite; provenance mapping W3C PROV.
v1.2	Caso di studio pubblico/sintetico, benchmark e usabilità

Versione	Obiettivo
	dell'human approval.
v2.0 candidate	Spec con conformance levels, normative language MUST/SHOULD/MAY e interoperabilità multi-runtime.
Standardizzazione eventuale	Solo dopo feedback, implementazioni indipendenti e validazione; possibile proposta in comunità/interoperability forums.

19. Conclusioni

Nel 2026 non manca la governance dell'IA in senso generale: esistono norme, risk framework, linee guida pubbliche e toolkit tecnici avanzati. Ciò che rimane fragile è la continuità tra l'autorità con cui una PA opera e l'autorità tecnica con cui un agente modifica il mondo. PICEE-PA affronta questo punto circoscrivendo l'unità di controllo all'azione e chiedendo che ogni azione significativa sia spiegabile come catena Policy-Identity-Capability-Execution-Evidence. AEE rende esplicito il contratto prima dell'azione; AEB rende ricostruibile ciò che è avvenuto dopo. La proposta è utile solo se resta interoperabile, minimizza l'overhead e viene sottoposta a test comparativi. Il passo successivo non è dichiararne l'originalità, ma implementarla e misurarla.

Appendice A - AEE schema concettuale

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "title": "PICEE-PA Administrative Execution Envelope",
  "required": ["aee_id", "purpose", "requester", "agent", "capability", "action_class", "policy"],
  "properties": {
    "aee_id": {"type": "string"},
    "purpose": {"type": "string"},
    "process": {"type": "string"},
    "requester": {"type": "object"},
    "agent": {"type": "object"},
    "delegation": {"type": "object"},
    "capability": {"type": "object"},
    "action_class": {"enum": ["L0", "L1", "L2", "L3"]},
    "approval": {"type": "object"},
    "policy": {"type": "object"},
    "versions": {"type": "object"},
    "expires_at": {"type": "string", "format": "date-time"}
  }
}
```

Appendice B - AEB schema concettuale

```
{
  "$schema": "https://json-schema.org/draft/2020-12/schema",
  "title": "PICEE-PA Administrative Evidence Bundle",
  "required": ["aeb_id", "aee_id", "decision", "execution", "timestamps"],
  "properties": {
    "aeb_id": {"type": "string"},
    "aee_id": {"type": "string"},
    "decision": {"enum": ["allow", "deny", "review", "error"]},
    "reason_code": {"type": "string"},
    "approval": {"type": "object"},

```

```

    "execution": {"type": "object"},
    "result": {"type": "object"},
    "provenance": {"type": "array"},
    "recovery": {"type": "object"},
    "versions": {"type": "object"},
    "timestamps": {"type": "object"},
    "evidence_hash": {"type": "string"}
  }
}

```

Riferimenti

- [1] Regolamento (UE) 2024/1689 (AI Act), testo consolidato al 27 luglio 2026, come modificato dal Regolamento (UE) 2026/1744. <https://eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:02024R1689-20260727>
- [2] Regolamento (UE) 2026/1744, semplificazione dell'attuazione delle regole armonizzate sull'IA. <https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng>
- [3] Consiglio dell'UE, Artificial Intelligence: final green light to simplify and streamline rules, 29 giugno 2026. <https://www.consilium.europa.eu/en/press/press-releases/2026/06/29/artificial-intelligence-council-gives-final-green-light-to-simplify-and-streamline-rules/>
- [4] Legge 23 settembre 2025, n. 132, Disposizioni e deleghe al Governo in materia di intelligenza artificiale. <https://www.gazzettaufficiale.it/eli/id/2025/09/25/25G00143/sg>
- [5] AgID, Determinazione n. 43 del 10 marzo 2026 - consultazione delle linee guida per sviluppo e procurement dell'IA nella PA. <https://trasparenza.agid.gov.it/page/103/details/5557/determinazione-del-direttore-generale-n-43-del-10-marzo-2026-avvio-delliter-di-consultazione-e-informazione-delle-linee-guida-per-lo-sviluppo-e-il-procurement-dellintelligenza-artificiale-nella-pubblica-amministrazione.html>
- [6] AgID, Bozza di Linee guida per lo sviluppo di sistemi di IA nella PA, 2026. https://www.agid.gov.it/sites/agid/files/2026-03/LLGG_Sviluppo_per%20consultazione%20pubblica.pdf
- [7] AgID, Bozza di Linee guida per il procurement di IA nella PA, 2026. https://www.agid.gov.it/sites/agid/files/2026-03/LLGG%20procurement_per%20consultazione%20pubblica.pdf
- [8] Italia Open Gov, Raccomandazioni sull'utilizzo dell'IA nella Pubblica Amministrazione, 31 luglio 2026. <https://open.gov.it/notizie/intelligenza-artificiale-pa-raccomandazioni>
- [9] JRC, Advancing AI adoption in EU public administrations: Future directions and opportunities under the Apply AI Strategy, 2026, JRC143539. <https://publications.jrc.ec.europa.eu/repository/handle/JRC143539>
- [10] Interoperable Europe, Public Sector AI and Interoperability Readiness (PAIR) - Inception Workshop, 2026. <https://interoperable-europe.ec.europa.eu/collection/ai-public-sector/news/pair-inception-workshop-0>
- [11] Interoperable Europe, AI in the public sector Collection / AI Toolbox, 29 giugno 2026. <https://interoperable-europe.ec.europa.eu/collection/portal-support/news/new-collection-ai-public-sector>
- [12] Interoperable Europe, SyRCI-IA - Human-Supervised AI for Routing Suggestions, Complaints and Compliments, 26 agosto 2026. <https://interoperable-europe.ec.europa.eu/collection/egovernment/solution/syrci-ia>
- [13] Government of Canada, Guide on the Use of Agentic Artificial Intelligence, 22 maggio 2026. <https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/responsible-use-ai/guide-use-agentic-artificial-intelligence.html>
- [14] UK Government Digital Service, AI Insights: Agentic AI, aggiornato 3 agosto 2026. <https://www.gov.uk/government/publications/ai-insights/ai-insights-agentic-ai-html>
- [15] Urban Institute, Responsible Agentic AI Playbook: A Practical Guide for State and Local Government Agencies, 19 agosto 2026. <https://www.urban.org/research/publication/responsible-agentic-ai-playbook>
- [16] Salah, M. et al., Before Agentic AI Scales in Government: The Democratic Authorization Gap, Frontiers in Political Science, accepted 19 agosto 2026. <https://www.frontiersin.org/journals/political-science/articles/10.3389/fpos.2026.1956489/full>
- [17] Passi, S.; Singh, R., The Oversight Fallacy: Why AI Agents Require More than Humans-in-the-Loop, Data & Society, luglio 2026. <https://datasociety.net/research-library/the-oversight-fallacy-why-ai-agents-require-more-than-humans-in-the-loop/>
- [18] Prencipe, G. et al., Transforming public administration workflows with multi-agent AI: A human-in-the-loop knowledge orchestration framework, Computers in Human Behavior Reports 23 (2026) 101253. <https://www.sciencedirect.com/science/article/pii/S2451958826003271>

- [19] NIST NCCoE, Accelerating the Adoption of Software and Artificial Intelligence Agent Identity and Authorization, Concept Paper, 5 febbraio 2026. <https://csrc.nist.gov/pubs/other/2026/02/05/accelerating-the-adoption-of-software-and-ai-agent/ipd>
- [20] NIST, Artificial Intelligence Risk Management Framework (AI RMF 1.0), 2023, con profili e lavori di aggiornamento successivi. <https://www.nist.gov/itl/ai-risk-management-framework>
- [21] OWASP, State of Agentic AI Security and Governance 2.01, 1 giugno 2026. <https://genai.owasp.org/>
- [22] Microsoft / Linux Foundation, Agent Governance Toolkit - Technical Charter, 2026. <https://github.com/microsoft/agent-governance-toolkit/blob/main/CHARTER.md>
- [23] Microsoft Agent Governance Toolkit, Agent Control Specification, draft 0.3.1-beta, review 31 luglio 2026. <https://github.com/microsoft/agent-governance-toolkit/blob/main/docs/packages/agent-control-specification.md>
- [24] Microsoft Agent Governance Toolkit, Agent Hypervisor Execution Control 1.0, draft 17 maggio 2026. <https://github.com/microsoft/agent-governance-toolkit/blob/main/docs/specs/AGENT-HYPERVISOR-EXECUTION-CONTROL-1.0.md>
- [25] Microsoft Agent Governance Toolkit, AgentMesh Identity and Trust 1.0, draft 17 maggio 2026. <https://github.com/microsoft/agent-governance-toolkit/blob/main/docs/specs/AGENTMESH-IDENTITY-TRUST-1.0.md>
- [26] Open Policy Agent, Policy-as-Code documentation. <https://www.openpolicyagent.org/docs/>
- [27] Cedar Policy Language, authorization-as-code documentation. <https://www.cedarpolicy.com/>
- [28] IETF RFC 9396, OAuth 2.0 Rich Authorization Requests, 2023. <https://www.rfc-editor.org/rfc/rfc9396>
- [29] W3C, PROV-O: The PROV Ontology, W3C Recommendation. <https://www.w3.org/TR/prov-o/>
- [30] ISO/IEC 42001:2023, Artificial intelligence - Management system. <https://www.iso.org/standard/81230.html>
- [31] NIST SP 800-207, Zero Trust Architecture, 2020. <https://csrc.nist.gov/pubs/sp/800/207/final>
- [32] Saltzer, J.H.; Schroeder, M.D., The Protection of Information in Computer Systems, Proceedings of the IEEE, 1975. <https://web.mit.edu/Saltzer/www/publications/protection/>